

AI-ASSISTED CYBERSECURITY RISK ASSESSMENT & SECURITY AUDIT PLATFORM

1. Project Background

In real life, a cybersecurity auditor does two major activities:

1. Risk Assessment (identify risk)
2. Security Audit (verify controls actually exist)

Many organizations fail security audits because they:

- claim policies exist
- but cannot provide evidence
- or controls are not implemented

Therefore, modern organizations use GRC (Governance, Risk, Compliance) systems to automate both risk analysis and audit verification. In this project, you will build a mini GRC & Audit platform that:

- evaluates cyber risk
- audits security controls
- stores audit evidence
- generates audit findings
- assisted by AI

2. Framework Selection (Choose ONE)

Each group must choose one framework and implement its audit controls:

1. NIST SP 800-37 Risk Management Framework (RMF — system authorization & control verification)
2. OCTAVE Allegro risk assessment methodology (risk-centric analysis)
3. NIST Cybersecurity Framework (CSF) (Identify–Protect–Detect–Respond–Recover)
4. ISO/IEC 27001 information security standard (ISMS & Annex A control audit)

Your system must follow the actual workflow of the selected framework.

3. Main System Capabilities

Your platform must work like a junior cybersecurity auditor assistant.

The system should be able to:

Activity	Description
Risk Assessment	Analyze assets, threats, and risk levels
Security Audit	Check whether controls exist and work
Evidence Collection	Store screenshots / documents
Compliance Check	Measure compliance level
AI Consultation	Provide audit advice
Reporting	Generate audit report

4. System Modules

MODULE 1 — User & Auditor Management

Roles:

- Admin
- Auditor
- Auditee (organization staff)

Functions:

- Login system
- Role-based access control
- Audit assignment

MODULE 2 — Organization Profile

Input:

- organization name
- business sector
- number of employees
- system type (web, mobile, internal network, cloud)

System determines: organization exposure level

MODULE 3 — Asset Inventory

Users register assets:

Field	Example
Asset Name	Student Database
Owner	IT Department
Location	Cloud Server
Type	Application / Server / Data
CIA Value	High / Medium / Low

System calculates asset criticality score.

MODULE 4 — Threat & Vulnerability Identification (OWASP-Based)

4.1 Purpose

This module identifies vulnerabilities affecting an application and links them to risk. The system workflow becomes: Asset → OWASP Vulnerability → Threat → Impact → Risk Score

4.2 Built-In Vulnerability Library (OWASP Top 10)

Students must pre-populate the database with the following vulnerabilities:

Injection Category

1. SQL Injection
2. Command Injection
3. LDAP Injection

Broken Authentication

4. Weak Password Policy
5. No Account Lockout
6. Session Hijacking

Sensitive Data Exposure

7. No HTTPS / TLS
8. Weak Encryption
9. Exposed Database Backup

Access Control Failures

10. IDOR (Insecure Direct Object Reference)
11. Privilege Escalation

Security Misconfiguration

12. Default Credentials
13. Directory Listing Enabled
14. Exposed Admin Panel
15. Open Unnecessary Ports

Cross-Site Attacks

16. Cross-Site Scripting (XSS)
17. Cross-Site Request Forgery (CSRF)

Logging & Monitoring Failure

18. No Audit Logs

Dependency & Software Issues

19. Outdated Server Software

4.3 Student System Behavior

When an auditor selects an asset (example: LMS Website), the system must show:

“Select vulnerabilities detected or suspected:”

Checkbox list:

- ☐ SQL Injection
- ☐ XSS
- ☐ CSRF
- ☐ Weak Password Policy
- ☐ Outdated Apache
- ☐ Exposed Port

After selection → system automatically:

1. assigns likelihood
2. suggests impact
3. calculates risk

4.4 Automatic Risk Mapping

Your system should automatically interpret:

Vulnerability	Impact Example
SQL Injection	Database theft
XSS	Account hijacking
CSRF	Unauthorized transaction
Weak password	Account takeover
No logging	Incident undetected
Outdated server	Remote exploit

Students must program at least basic rule logic (no need for real scanning).

4.5 Connection to Security Audit Module

This module MUST connect to the audit checklist.

Example: If auditor selects: “Weak Password Policy”

The audit module automatically creates a checklist item: “Verify password policy enforces minimum 8 characters and complexity.”

If auditor selects: “No HTTPS”

Checklist: “Verify TLS certificate installed and HTTPS enforced.”

4.6 AI Feature Integration

The AI assistant should be able to explain vulnerabilities. Example student query: “Explain SQL Injection risk to a university management in non-technical language.”

AI response:

- what it is
- business impact
- recommendation

MODULE 5 — Risk Assessment Engine

You MUST implement: $\text{Risk} = \text{Likelihood} \times \text{Impact}$

Output:

- risk score
- risk level (Low / Medium / High / Critical)
- risk matrix (table/heatmap)

SECURITY AUDIT MODULE

This is the difference between a risk analyst and a security auditor. The system must audit whether security controls actually exist.

MODULE 6 — Control Audit Checklist

The system must provide an audit checklist based on the chosen framework.

Examples:

If ISO 27001

Audit items:

- password policy
- backup policy
- access control
- antivirus
- logging
- incident response procedure

If NIST CSF

Audit by functions:

- Identify
- Protect
- Detect
- Respond
- Recover

If RMF

Audit security controls:

- authentication
- audit logging
- encryption
- patch management

Auditor marks:

- Compliant
- Partially Compliant
- Non-Compliant
- Not Applicable

MODULE 7 — Audit Evidence Collection

The system must allow uploading:

- screenshots
- policy documents (PDF)
- configuration export
- photos of server room

This simulates real audit evidence.

MODULE 8 — Compliance Scoring

The platform automatically calculates:

Compliance % = (number of compliant controls ÷ total controls) × 100

Output example:

- 85% → Compliant
- 60% → Needs Improvement
- 40% → Non-Compliant

MODULE 9 — Audit Findings Generator

System automatically creates audit findings:

Each finding contains:

- issue
- risk
- affected asset
- recommendation

Example:

Finding: “Database server does not enforce strong password policy.”

Risk: Unauthorized access to academic records.

MODULE 10 — AI Auditor Assistant

Your system must include an AI feature.

Choose at least ONE:

Option A — AI Audit Advisor

User asks: “Is not having backup dangerous?”

AI explains the risk.

Option B — AI Report Writer

System automatically writes:

- Executive summary
- Audit conclusion
- Recommendations

Option C — AI Control Recommendation

AI suggests mitigation steps.

Example: “Enable multi-factor authentication and account lockout after 5 failed logins.”

Option D — AI Vulnerability Explainer

AI explains:

- SQL Injection
 - XSS
 - Phishing
- in non-technical language for management.

MODULE 11 — Report Generator

The system must export a Security Audit Report (PDF/DOCX).

Report contents:

1. Executive summary
2. Scope of audit
3. Methodology (selected framework)
4. Asset list
5. Risk assessment
6. Compliance result
7. Audit findings
8. AI recommendations
9. Final audit opinion

Final Opinion:

- Secure
- Acceptable Risk

- Needs Immediate Action

5. Required Documentation

Students must submit:

- Sample audit evidence
- User manual/Documentations